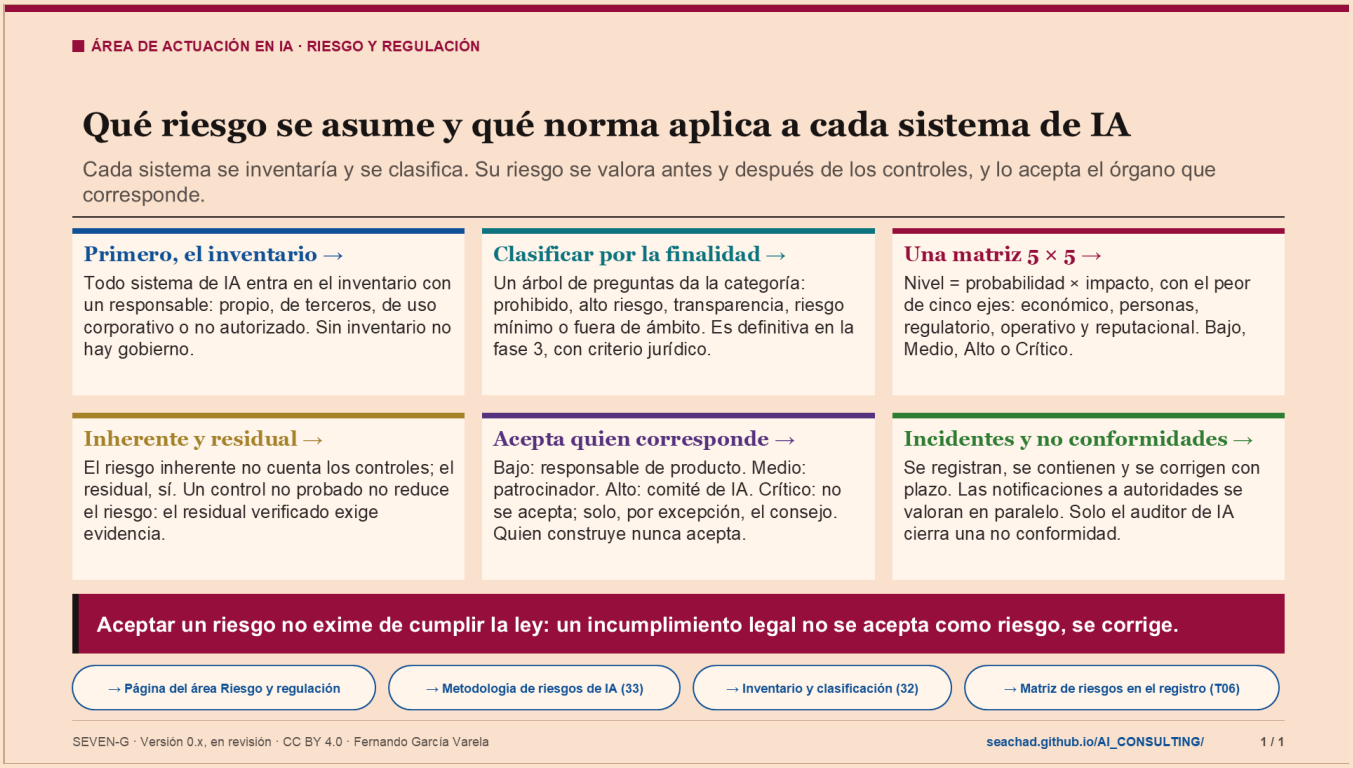


Notas

Esta slide resume el área de actuación Riesgo y regulación de SEVEN-G. Responde a dos preguntas que el consejo necesita contestar para cada sistema de IA: qué riesgo asume la compañía y qué norma le aplica. La respuesta tiene seis piezas, que se leen en orden.

- Primero, el inventario. Se inventarían todos los sistemas de IA de cuatro tipos de uso: iniciativas propias, IA de terceros integrada en procesos, uso corporativo de herramientas de propósito general y uso no autorizado. Cada sistema tiene un responsable con nombre, no un área genérica. Por qué importa: sin saber qué sistemas existen, no se pueden gestionar riesgos, cumplir obligaciones ni informar al consejo (documento 32).
- Clasificar por la finalidad. Un árbol de preguntas, basado en el Reglamento Europeo de IA, da la categoría del sistema: prohibido, alto riesgo, obligaciones de transparencia, riesgo mínimo o fuera de ámbito. Se clasifica por la finalidad prevista, no por la tecnología. La clasificación es provisional en la fase 0 y definitiva en la fase 3, con criterio jurídico cualificado. Ante la duda, se aplica la categoría más exigente.
- Una matriz 5 × 5. El nivel de riesgo es probabilidad por impacto, cada uno de 1 a 5. El impacto es el peor de cinco ejes: económico, personas y derechos, regulatorio, operativo y reputacional. No se promedia. Hay cuatro niveles: Bajo (1 a 4), Medio (5 a 9), Alto (10 a 15) y Crítico (16 a 25).
- Inherente y residual. El riesgo inherente es el nivel sin los controles específicos de la iniciativa. El residual es el nivel con controles: objetivo en el diseño y verificado cuando hay evidencia de que los controles funcionan. Un control no probado no reduce el riesgo verificado.
- Acepta quien corresponde. Cada nivel residual lo acepta un órgano distinto. El residual Crítico no se acepta; solo por excepción, el consejo o su comisión delegada. Un residual Crítico sin esa aprobación bloquea la puerta de viabilidad (G3) y la de puesta en producción (G5).
- Incidentes y no conformidades. Un incidente de IA es un suceso en el que un sistema causa o puede causar daño. Una no conformidad es el incumplimiento de un requisito obligatorio del marco. Los dos se

registran, se contienen y se corrigen con plazo.

Un ejemplo con datos ficticios del registro de ejemplo del sitio: el asistente conversacional de atención a clientes (IA-2025-002) se clasifica con obligaciones de transparencia, porque las personas conversan con una IA. Su riesgo de que una inyección de instrucciones revele datos de otro cliente es Crítico sin controles (4 × 4 = 16) y Medio con controles probados (2 × 4 = 8). Por eso lo acepta el patrocinador, con la conformidad del responsable de riesgos de IA.

Aviso importante: SEVEN-G no es asesoramiento jurídico ni garantiza el cumplimiento de ninguna norma. Cada organización identifica la normativa que le aplica, también la de su sector, y verifica su vigencia con asesoramiento cualificado (documento 34).

Pregunta para el aula: en su organización, ¿quién firma hoy la aceptación de un riesgo alto de un sistema de IA? ¿Es la misma persona que lo construye?

FUENTES Y ENLACES

- **Página del área Riesgo y regulación** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/es/areas/riesgo.html
- **Documento 33 · Metodología de riesgos de IA** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/es/33_SEVEN-G_Metodologia_de_riesgos_de_IA.html
- **Documento 32 · Inventario y clasificación regulatoria** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/es/32_SEVEN-G_Inventario_y_clasificacion_regulatoria.html
- **Documento 34 §1 · Alcance y responsabilidad del mapeo regulatorio** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/es/34_SEVEN-G_Mapeo_regulatorio.html#objeto-y-alcance
- **Documento 37 · No conformidades e incidentes** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/es/37_SEVEN-G_No_conformidades_e_incidentes.html
- **Reglamento (UE) 2024/1689 (Reglamento Europeo de IA), EUR-Lex** https://eur-lex.europa.eu/eli/reg/2024/1689/oj/spa
- **Metodología de riesgos de IA (33)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/es/33_SEVEN-G_Metodologia_de_riesgos_de_IA.html
- **Inventario y clasificación (32)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/es/32_SEVEN-G_Inventario_y_clasificacion_regulatoria.html
- **Matriz de riesgos en el registro (T06)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/herramientas/T01_registro_iniciativas/registro.html

AVISO LEGAL

Aviso legal: ayuda metodológica genérica y gratuita, «tal cual» y con fines informativos; no es asesoramiento jurídico ni está revisada jurídicamente para ningún caso. Cada organización la adapta y es responsable de su revisión legal y de su cumplimiento regulatorio; puede no recoger cambios normativos recientes. En la máxima medida permitida por la ley, el autor no asume responsabilidad alguna por los efectos de su aplicación. No otorga certificación de ningún tipo. Detalle en el documento 93.

CC BY 4.0 (contenidos) · MIT (código) · Fernando García Varela · seachad.github.io/AI_CONSULTING/